



University
of Glasgow

FRONT MATTER TO BE REPLACED
DayOfWeek, DayOfMonth Month 2XXX
XX.XX am/pm – XX.XX am/pm
(1 hour 30 minutes)

DEGREES OF MSci, MEng, BEng, BSc, MA and MA (Social Sciences)

SECURED SOFTWARE ENGINEERING MOCK EXAM

Answer all 3 questions

This examination paper is an online, open book assessment and is worth a total of 70 marks

For this exam, you will often be required to provide justification or rationale for answers to attain the available marks for the questions. It is recommended you provide answers that do not exceed 200 words to maximize the time available in the exam.

1. **Case Study.** You are part of a team that has been tasked with developing a web-based application for a healthcare organisation.

In the given context,

- (a) Considering the critical importance of security for the application, your team has identified the following top FIVE assets that require protection:

- Patient's medical history (test results, communication, treatment plans);
- Medical prescriptions;
- Doctor/medical staff/ Patients/other accounts credentials;
- Connectivity with large number of healthcare providers and pharmacies;
- New Patient registration system;

Argue and justify why these assets are critical to the security and operation of the mobile application. [5]

- (b) Your team has identified the following FIVE specific threats for these assets in the application.

- Patient's medical history (test results, communication, treatment plans);
 - **Critical Threat:** Unauthorized access and disclosure.
- Medical prescriptions:
 - **Critical Threat:** Excessive data retention.
 - Explanation: Holding onto data longer than necessary can increase the risk of it being compromised.
- Doctor/medical staff/ Patients/other accounts credentials:
 - **Critical Threat:** Attackers trying to get and tamper with patient data/unregistered patients trying to register themselves.
- Connectivity with large number of healthcare providers and pharmacies:
 - **Critical Threat:** Inadequate network segmentation.
 - Explanation: Without proper segmentation, a breach in one part of the network can easily spread to other areas, compromising the entire system.
- New Patient registration system:
 - **Critical Threat:** Use of outdated software.

For each identified threat, discuss its relevance to the asset it is associated with, considering the context of a financial application. If you believe a threat is not relevant or critical for its associated asset, justify your position. [5]

(c) Consider TWO design choices for enhancing security within the financial transaction application:

- Design Choice A: Implementing the STRIDE model to systematically identify security threats.
- Design Choice B: Employing the Common Vulnerability Scoring System (CVSS) to quantitatively assess and prioritize system vulnerabilities based on their severity, impact, and complexity.

Select one design choice and justify your decision by providing reasons that demonstrate the potential effectiveness of your chosen design choice in identifying and mitigating threats. [4]

(d) For the identified threats, what would be your FIVE countermeasures in the Software Development Life Cycle (SDLC)? (Note: it can be a countermeasure in any phase) [5]

2. The Driver and Vehicle Licensing Agency (DVLA) is a UK government agency responsible for maintaining a database of drivers and vehicles in the UK. Its web-based software application is used by millions of people to apply for driving licenses, renew vehicle registrations, and perform other vehicle-related transactions.

In the given context,

- (a) Is relying solely on password authentication adequate to ensure the security and integrity of the system and its data? If not, what alternative or additional authentication method would better address the DVLA's security requirements, and why would this approach be more effective in safeguarding against potential security threats? [4]
- (b) Design and justify a tailored authorization strategy, detailing specific access rights for two user roles—drivers and administrative staff—within the DVLA's web-based software application. This strategy should address access to functionalities such as license applications, vehicle registrations, transaction histories, and personal data management. Explain the rationale behind the designated access permissions for each role, ensuring the strategy aligns with the security and operational needs of the DVLA system. [5]
- (c) The DVLA IT team wants to implement biometrics-based authentication in their products considering the options of Fingerprints, Iris Scan, and Facial recognition.

Argue for any TWO highly critical security/privacy issues associated to Fingerprints, Iris Scan and Facial recognition that can arise using these THREE mechanisms. [4]

- (d) The DVLA IT Team is spearheading a strategic overhaul of its cybersecurity framework to address and neutralize modern cyber threats. The focus is on two prevalent attack vectors: Data Manipulation Attacks and Unauthorized Session Control.
- Data Manipulation Attacks: target the integrity of the data within an application's database.
 - Unauthorized Session Control: involves an attacker gaining control over a legitimate user's application session.

To counter these threats, TWO innovative defence strategies have been proposed by the security team:

- Jim is a supporter of the Robust Request Checking Mechanism. By implementing comprehensive input validation, Jim believes that the application can thwart attacks that attempt to inject or manipulate data.
- Morgan is focused on combating Compromised Session Management. She argues that the principle of least privilege is essential in creating an Enhanced Session Shielding Protocol.

As a secure software engineering student, your task is to meticulously evaluate each claim within the app's framework against two aforementioned threats. [6]

- (e) The DVLA IT Team is advancing their efforts to enhance the security of their application and seeks guidance on formulating a comprehensive security testing strategy. You are assigned to evaluate and rank THREE methodologies—Fuzz Testing, Static Code Analysis, and Threat Modeling—according to their significance and efficacy in uncovering and addressing potential vulnerabilities. Provide detailed reasoning for your prioritization, highlighting how each method contributes to the overall security of the application. [8]

3. (a) You are being asked to consult with a software company who are looking to put together a security policy. You are told there are three Confidentiality levels ordered in the following lattice model:

Top Secret < Secret < Unclassified, such that

- 'Top Secret' is the highest security level;
- 'Secret' is the standard security level;
- 'unclassified' is the lowest security level.

You are asked to use the Bell-LaPadula model simple security and * property to define permissions for users in the following format:

User Role: Permission for Top Secret, Permission for Secret, Permission for Unclassified, where, where

- 'NULL' for not authorized
- '-r' for read permission;
- '-w' for write permission; and
- '-rw' for both read and write permissions.

For example, Charlie: NULL for Top Secret, -r for Secret, -rw for Unclassified.

Follow on the example and format given, and define permissions for the following THREE types of users: Alice [Top Secret], Bob [Secret], and Eve [Unclassified].

[9]

- (b) Assuming that a software company has implemented the Biba model's low watermark policy for integrity, what would be the consequences of a user at the "Top Secret" confidentiality level (higher level) attempting to modify data (an object) with a "Secret" integrity level (lower level). Provide a brief explanation of the consequences. [3]

- (c) Analyze the provided "AssignmentSubmissionSystem" Java class to perform Taint Flow Analysis. Then,

- Identifying the source of tainted data;
- Tracing and listing the flow of this data through the program;
- Explain how this tainted data is used in a potentially unsafe manner.
- Refactoring the provided Java code to eliminate/mitigate the identified unsafe behavior/vulnerability (You can either refactor the provided Java code or describe it in your own words).

[6]

Listing 1: AssignmentSubmissionSystem

```
1 import java.util.Scanner;
```

```

2
3 public class AssignmentSubmissionSystem {
4
5     public static void main(String[] args) {
6
7         Scanner scanner = new Scanner(System.in);
8
9         // Assume that the input is coming from a user-submitted
10        form field
11        System.out.print("Enter your name: ");
12        String studentName = scanner.nextLine();
13
14        // Assume that the input is coming from a user-submitted
15        form field
16        System.out.print("Enter the assignment title: ");
17        String assignmentTitle = scanner.nextLine();
18
19        // Assume that the input is coming from a user-submitted
20        form field
21        System.out.print("Enter the path to your assignment file:
22        ");
23        String assignmentFilePath = scanner.nextLine();
24
25        // Upload the assignment file to the server
26        if (!uploadFile(assignmentFilePath)) {
27            System.out.println("Failed to upload file.");
28            return;
29        }
30
31        // Save the assignment submission to the database
32        if (!saveSubmission(studentName, assignmentTitle,
33        assignmentFilePath)) {
34            System.out.println("Failed to save submission.");
35            return;
36        }
37
38        // Display a success message
39        System.out.println("Submission successful.");
40    }
41
42    private static boolean uploadFile(String filePath) {
43        // Assume that this method uploads the given file to the
44        server
45        // and returns true if the upload is successful, false

```

```

41         otherwise
42         return true;
43     }
44     private static boolean saveSubmission(String studentName,
45         String assignmentTitle, String assignmentFilePath) {
46         // Assume that this method saves the assignment
47         submission to a database
48         // and returns true if the save is successful, false
49         otherwise
50         return true;
51     }
52 }

```

- (d) A company wants to do an audit of its software for GDPR compliance. Which three Secure Software Engineering methods you would recommend for this purpose? Give a brief explanation for each method. [6]